occur.[443] Under this assumption, a customer is then able to choose a financial firm that offers a service of a quality that meets his or her preferences.[444]

In the context of covered institutions—firms whose services frequently involve custody of highly sensitive customer information—the assumption of complete information is unrealistic. Customers have little visibility into the internal processes of a firm and those of its service providers, so it is impractical for them to directly observe the level of customer information safeguards that a firm is employing.[445] In addition, customers generally do not know how a firm would respond to a breach, including whether and to what extent a firm would inform its customers about such breach.[446] In fact, firms often lack incentives to voluntarily disclose when information breaches occur (and likely have substantial incentives to avoid such disclosures). Hence, customer information could be compromised without the customers being informed or with the customers being only partially informed.[447] As a result, prospective customers have limited ability to choose a covered institution that is offering the service that most closely meets their needs. In addition, current customers may be paying for a service that is of lower quality than they expect.[448] In both cases, customers have limited ability to avoid covered institutions

---

443 The response includes elements such as detection, assessment, recovery, and the communication of the breach to the firm's customers.

444 For example, a customer may be particularly averse to risk and consequently choose a financial firm with a higher level of information safeguards, even if this firm's service is being provided for a higher price.

445 As discussed below, customers already receive some information on covered institutions' customer information safeguards and disclosure of nonpublic personal information to third parties. *See infra* section IV.C.2.c.

446 Even if a firm has been the subject of a breach in the past, it may have changed its procedures since the last breach. In this case, even knowing the firm's response to a previous breach would not be fully informative to customers.

447 Here, customers are "partially informed" if the information they receive about the breach is not sufficient to allow them to take appropriate mitigating actions.

448 It could also be the case that the true quality of the service is higher than what customers expect. In this case, the customers would not be harmed, but the firm would not be fully realizing the benefits from its investment in customer information safeguards.

that fail to protect customer information to the level expected by these customers.[449] Hence, this information asymmetry prevents market forces from penalizing covered institutions that fail to protect customer information, and therefore prevents market forces from yielding economically efficient outcomes. This market failure serves as the economic rationale for this regulatory intervention.

The information asymmetry can lead to three inefficiencies. First, the information asymmetry about specific information breaches that have occurred prevents individual customers whose information has been compromised from taking timely actions (e.g., increased monitoring of account activity or placing blocks on credit reports) necessary to mitigate the potential consequences of such breaches. Second, the information asymmetry about covered institutions' efforts at avoiding and limiting the consequences of such breaches can lead to customers choosing financial firms with levels of safeguards different from what they expect, which can result in customers choosing firms that they would not have otherwise chosen if provided with better information. Third, this asymmetry can also reduce covered institutions' incentives to sufficiently safeguard customer information. As a result, they could devote too little effort (i.e., "underspend") toward safeguarding this information, thereby increasing the probability of the

---

449 The release of information about data breaches can lead to loss of customers, reputational harm, litigation, or regulatory scrutiny. *See, e.g.*, U.S. Fed. Trade Comm'n, Press Release, *Equifax to Pay $575 Million as Part of Settlement with FTC, CFPB, and States Related to 2017 Data Breach* (July 22, 2019), *available at* https://www.ftc.gov/news-events/news/press-releases/2019/07/equifax-pay-575-million-part-settlement-ftc-cfpb-states-related-2017-data-breach. *See also* James Mackay*, 5 Damaging Consequences of Data Breach: Protect Your Assets* (Dec. 15, 2023), *available at* https://www.metacompliance.com/blog/data-breaches/5-damaging-consequences-of-a-data-breach (stating that research has shown that up to a third of customers in retail, finance and healthcare would stop doing business with organizations that have been breached and that 85% would tell others about their experience) and *2019 Consumer Survey: Trust and Accountability in the Era of Data Misuse*, PING IDENTITY, *available at* https://www.pingidentity.com/en/resources/content-library/misc/3464-2019-consumer-survey-trust-accountability.html (last visited Apr. 9, 2024) (describing a survey of more than 4,000 individuals across the U.S., U.K., Australia, France, and Germany which found that 81% of people would stop engaging with a brand online following a data breach; this includes 25% who would stop interacting with the brand in any capacity).

information being compromised in the first place.[450] This scenario is often characterized as a moral hazard problem. When an agent's actions cannot be observed or directly contracted for by the principal, it is difficult to induce the agent to supply the proper amounts of productive inputs.[451] In other words, information asymmetry prevents covered institutions (the agents) that spend more effort on safeguarding customer information from having customers (the principals) recognize their extra efforts and therefore prevents the covered institutions from realizing some of the benefits associated with this additional effort.[452] This reduces the incentives for covered institutions to exert effort towards safeguarding information.[453]

We expect the final amendments may mitigate the inefficiencies described above in several ways. First, by helping facilitate timely and informative notices to customers when their information is compromised, the amendments may mitigate information asymmetries around the

---

450 For example, in a recent survey of financial firms, 58% of the respondents self-reported "underspending" on cybersecurity. *See* McKinsey & Co. and Institute of International Finance, *IIF/McKinsey Cyber Resilience Survey* (Mar. 2020), *available at* https://www.iif.com/portals/0/Files/content/cyber_resilience_survey_3.20.2020_print.pdf ("IIF/McKinsey Report"). A total of 27 companies participated in the survey, with 23 having a global footprint. Approximately half of respondents were European or U.S. Globally Systemically Important Banks (G-SIBs).

451 *See, e.g.*, Bengt Holmstrom, *Moral Hazard and Observability*, 10 BELL J. ECON. 74-91 (1979) ("It has long been recognized that a problem of moral hazard may arise when individuals engage in risk sharing under conditions such that their privately taken actions affect the probability distribution of the outcome […]. The source of this moral hazard or incentive problem is an asymmetry of information among individuals that results because individual actions cannot be observed and hence contracted upon."); Bengt Holmstrom, *Moral Hazard in Teams*, 13 BELL J. ECON. 324-340 (1982) ("Moral hazard refers to the problem of inducing agents to supply proper amounts of productive inputs when their actions cannot be observed and contracted for directly."). In other contexts, moral hazard refers to a party taking on excessive risk when knowing another party will be responsible for negative outcomes. This alternative definition may be viewed as a special case within the broader economic definition associated with the difficulty of contracting for privately taken actions. *See, e.g.*, Adam Carpenter, *Moral Hazard Definition*, U.S. NEWS (Aug. 11, 2022; updated Dec. 8, 2023), *available at* https://money.usnews.com/investing/term/moral-hazard.

452 Such benefits include attracting customers who are willing to pay more for enhanced security, thereby allowing these covered institutions to charge a higher price for their services.

453 This is not to say that firms do not have any incentives to invest in customer information safeguards. As discussed below, firms themselves are hurt by incidents resulting in unauthorized access to or use of customer information and therefore have incentives to invest in safeguards even when these incidents remain unknown to their customers. *See infra* section IV.C.1.

compromise of information and improve customers' ability to take appropriate remedial actions. Second, by revealing when such events occur, the amendments may help customers draw inferences about a covered institution's efforts toward protecting customer information, which might help inform their choice of covered institution and reduce the probability of customers inadvertently choosing a firm that is less likely to meet their preferences or needs.[454] This, in turn, might provide firms with greater incentives to exert effort toward protecting customer information,[455] thereby mitigating the moral hazard problem. And, by imposing a regulatory requirement to develop, implement, and maintain policies and procedures, the final amendments might further enhance firms' cybersecurity preparations and will restrict firms' ability to limit efforts in these areas.

The effectiveness of the final amendments at mitigating these problems will depend on several factors. First, the effectiveness of the amendments will depend on the degree to which breach notification provides customers with sufficient actionable information in a sufficient timeframe to help them mitigate the effects of the compromise of sensitive customer information. Second, it will depend on customers' ability to draw inferences on a covered institution's protection of customer information based on the notifications they receive, or the absence thereof.[456] Third, it will also depend on the degree to which the prospect of issuing such notices—and the prospect of the reputational harm, litigation, and regulatory scrutiny that could

---

454 In the case of transfer agents and funding portals, such effects would usually be mediated through security-issuing firms' choice of transfer agent or funding portal and therefore be less direct. Nonetheless we expect that, all else being equal, firms would prefer to avoid employing the services of transfer agents or funding portals that have been unable to prevent investors' information from being compromised.

455 *See, e.g.*, Richard J. Sullivan & Jesse Leigh Maniff, *Data Breach Notification Laws*, 101 ECON. REV. 65 (2016) ("Sullivan & Maniff").

456 Because breaches can happen even at firms with very high customer information safeguards, and because firms with very low levels of safeguards might never be victim of a breach, customers' ability to draw inferences could be limited.

ensue—helps alleviate underspending on safeguarding customer information.[457] These factors themselves depend on the extent to which covered institutions already have in place processes and practices that satisfy the final requirements and therefore on the extent to which the amendments will induce improvements to existing practices relative to the baseline.[458]

Some commenters supported generally the economic rationale in the Proposing Release.[459] Some of these commenters expressed that the asymmetric information market failure was present in this context.[460] Some commenters stated that this market failure could lead to inefficiencies.[461] One commenter stated that firms "either seek to skirt notification requirements altogether or provide vague or confusing notifications," preventing affected individuals from taking timely actions, and that firms' self-interest could lead them to fail to notify customers

---

457 Although empirical evidence on the effectiveness of notification breach laws (that is, on how such laws help individuals mitigate the effects of a breach and how they prevent such breaches from occurring by influencing firms' levels of safeguards) is quite limited, extant studies suggest that such laws protect consumers from harm. *See* Sasha Romanosky et al., *Do Data Breach Disclosure Laws Reduce Identity Theft?*, 30 J. POL'Y ANALYSIS & MGMT 256 (2011); *see also* Sullivan & Maniff, *supra* footnote 455.

458 This economic analysis presents evidence suggesting that the inefficiencies described above do exist in this context, and therefore suggesting that covered institutions' existing processes and practices can be improved. *See infra* footnote 464 and accompanying text for evidence that some notices do not currently contain sufficient information for customers to take appropriate mitigating actions and *infra* section IV.D.1.b(2) for evidence that such notices are sometimes sent with such delay as to make it difficult for customers to take "timely" mitigating actions; *see also supra* footnote 449 for evidence that customers would modify the firms with which they do business if they learned that this firm was the victim of a breach, suggesting that such customers do draw inferences on firms' customer information safeguards when learning that breaches occur and modify their behavior as a result; *see also infra* section IV.C.1 for evidence that some firms are currently underspending on cybersecurity.

459 *See, e.g.*, Nasdaq Comment Letter; FSI Comment Letter.

460 *See, e.g.*, Better Markets Comment Letter ("But companies will not always disclose data breaches to affected individuals voluntarily. They may be concerned about the damage to their reputation and their bottom line from disclosing a breach."); EPIC Comment Letter ("A company has better visibility than its consumers do into the threats to the privacy and security of consumer data entrusted to that company's custody; and the company's interests are not directly aligned with those of its consumers."); Nasdaq Comment Letter ("Requiring various financial institutions and market entities to address these cybersecurity risks through policies and procedures, incident response programs, third-party management, notifications and/or public disclosures can promote transparency and consistency. Investors, issuers and other market participants benefit from healthy capital markets that promote trust and transparency.").

461 *See, e.g.*, EPIC Comment Letter; Better Markets Comment Letter.

affected by a breach.[462] Another commenter stated its view that firms have a natural tendency to want to avoid making disclosures that could incur liability or lead to a loss of customers.[463] Another commenter stated that beginning in the fourth quarter of 2021, less information started being included in data breach notices and that in 2022, only 34 percent of notices included information about the breaches and their victims.[464] This commenter further added that this lack of actionable information in breach notices prevented individuals from effectively judging the risks they faced and from taking the appropriate actions to protect themselves.[465] One commenter supported the economic rationale of the Proposing Release, stating that stronger notification requirements could effectively incentivize covered institutions to improve their data security practices in order to avoid the reputational harm associated with distributing breach notices.[466]

Other commenters disagreed with the economic rationale in the Proposing Release and stated that covered institutions' level of customer information safeguards and/or breach notification practices were already adequate, and that existing regulation made the amendments unnecessary.[467] We disagree with these commenters that the amendments are unnecessary, even

---

462 *See* EPIC Comment Letter.

463 *See* NASAA Comment Letter.

464 *See* Better Markets Comment Letter, citing IDENTITY THEFT RESOURCE CENTER, DATA BREACH ANNUAL REPORT (Jan 2023), *available at* https://www.idtheftcenter.org/wp-content/uploads/2023/01/ITRC_2022-Data-Breach-Report_Final-1.pdf ("IRTC Data Breach Annual Report").

465 *See* Better Markets Comment Letter.

466 *See* EPIC Comment Letter. This commenter also cited Federal Communications Commission (FCC), *Data Breach Reporting Requirements*, Proposed Rule, FCC 22-102, 88 FR 3953 (Jan. 23, 2023) (stating that the FCC "anticipate[s] that requiring notification for accidental breaches will encourage telecommunications carriers to adopt stronger data security practices and will help us identify and confront systemic network vulnerabilities").

467 *See* ASA Comment Letter (stating that the proposal was not "supported by evidence that brokers are fundamentally failing in their obligations to safeguard investor information and notify government authorities – within applicable Federal and state law – when a significant breach of sensitive information has occurred" and that the Proposing Release did not "provide any discussion about how current broker-dealer cybersecurity and customer notification policies are deficient or in need of a regulatory fix"); ACLI Comment Letter ("The ACLI's members already comply with much of the Proposal's content through state

if some covered institutions may already have policies and procedures in place that satisfy the final amendments' requirements. We have discussed, here and in the Proposing Release, the information asymmetries that prevent customers from knowing whether or how they will be notified of a data breach and from choosing firms based on the level of their customer information safeguards.[468] Furthermore, in addition to describing existing requirements and guidance available to (and potentially adopted by) covered institutions addressing customer information safeguards and customer notification, we have described (here and in the Proposing Release) a variety of practices and state law requirements that could lead to different notification outcomes depending on where the customer resides.[469] In particular, we have described a variety of delays and inconsistencies in notification under existing requirements.[470] Hence, the Proposing Release described in detail the existing regulatory framework and analyzed the benefits and costs of the proposed amendments relative to this framework. In addition, as discussed above, some commenters provided additional evidence of deficiencies in existing practices.[471] Moreover, in response to commenters, we have supplemented the analysis of the amendments' benefits and

---

regulations, such as those that require companies to maintain written cybersecurity policies and procedures, respond to cyber incidents, notify authorities and consumers of certain cyber incidents, and dispose of consumer data. However, we are concerned with the Proposal's shortened notification timeframes and expanded scope."); CAI Comment Letter (stating that "[n]otice currently is given to individuals whose information is reasonably believed to have potentially been affected after the findings of the investigation are determined," that it "believes this current practice is an appropriate and common-sense approach to notification," and that "[t]he new notice requirement proposed under Proposed Rule 30(b) would simply add another layer on top of these existing requirements and would likely go entirely unnoticed by consumers"); Computershare Comment Letter ("Computershare believes Proposed Reg S-P is an unnecessary regulation for transfer agents, as they are already subject, either directly or indirectly, to state, federal or provincial laws designed to protect personal information of securityholders and requiring breach notification."); STA Comment Letter 2 (stating that the proposed amendments would not "meaningfully increase the safeguarding of shareholder information" and instead "cause ambiguity among competing laws.").

468 *See* Proposing Release at section III.B.

469 *See* Proposing Release at section III.C; *see also infra* section IV.C.2.

470 *See* Proposing Release at section III.C.2.a; *see also infra* section IV.C.2.a.

471 *See supra* footnote 460 and accompanying text.

costs, describing in greater detail the changes made by the final amendments over the baseline.[472] We summarize these changes below. We have also supplemented the analysis of the expected benefits and costs of expanding the scope of the safeguards and disposal rules to include transfer agents.[473]

In particular, the variety of practices and state law requirements that could lead to different notification outcomes under existing requirements provides a further rationale for the rule and motivated specific differences in the final amendments relative to state laws. We discuss the effects of these differences in detail below,[474] but for example, the required timing of notification in the final amendments is stricter than under many state laws. The analysis in section IV.D.1.b(2) provides evidence that currently, many customers receive notification long after the event. The amendments are designed to help ensure that customers receive notification in a timely manner. In addition, the notification obligation covers a set of customer information that is broader than in many state laws, thereby covering more data breaches. Moreover, the final amendments require certain information to be included in the notice sent to customers. This requirement will help ensure that customers receive relevant information, allowing them to take appropriate mitigating actions in case of a breach. Hence, while the final amendments contain some requirements that are similar to those in some existing state laws, the final requirements are stricter than many state laws and may therefore lead to customers receiving additional, timelier, and more relevant notices than under existing regulations.[475] In addition, variations in state law

---

472 *See infra* section IV.D.

473 *See infra* section IV.D.2.b.

474 *See infra* section IV.D.1.

475 It is possible that, because of the overlap with state laws, some covered institutions already have policies and procedures in place satisfying the final amendments' requirements. For these institutions and their customers, both the benefits and the costs of the amendments will be limited.

requirements highlight the need for a consistent Federal minimum standard for covered institutions. Such a standard will protect all customers regardless of their state of residence and reduce the potential confusion that could result from customers in one state receiving notice of an incident while customers in another state do not.

Other commenters stated that the analysis in the Proposing Release underestimated the costs of the amendments.[476] Some commenters also stated that the proposed amendments in general would be very costly to implement for smaller covered institutions.[477] As discussed more fully below, we expect some of the changes made to the final amendments to result in lower costs relative to the proposal.[478] For example, the changes made to the service provider provisions of the amendments (requiring that covered institutions oversee service providers instead of requiring written contracts between covered institutions and their service providers, and requiring that the covered institution's policies and procedures be reasonably designed to ensure service providers take appropriate measures to notify covered institutions of an applicable breach in security within 72 hours instead of 48 hours) may reduce some costs relative to the proposal and facilitate their implementation, especially for smaller covered institutions.[479] In addition, in a change from proposal, we are adopting longer compliance periods for all covered institutions, and an even longer compliance period for smaller covered institutions,[480] who are less likely to already have policies and procedures broadly consistent with the final amendments.

---

476 *See, e.g.*, IAA Comment Letter 1 ("We urge the Commission to undertake a more expansive, accurate, and quantifiable assessment of the specific and cumulative costs, burdens, and economic effects that would be placed on advisers by the proposed requirements, as well as of the potential unintended consequences for their clients.").

477 *See, e.g.*, ASA Comment Letter; IAA Comment Letter 1.

478 *See, e.g.*, *infra* sections IV.D.1.c and IV.E.

479 *See supra* section II.A.4; *infra* section IV.D.1.c.

480 *See supra* section II.F.

C. Baseline

The baseline against which the costs, the benefits, and the effects on efficiency, competition, and capital formation of the final amendments are measured consists of current requirements for customer notification and information safeguards, current practice as it relates to customer notification and information safeguards, and the current market structure and regulatory framework. The economic analysis appropriately considers existing regulatory requirements, including recently adopted Commission rules as well as state, federal, and foreign laws and regulations, as part of the economic baseline against which the costs and benefits of the final amendments are measured.[481]

Several commenters requested that the Commission consider interactions between the economic effects of the proposal and other recent Commission proposals.[482] The Commission adopted several of the rules mentioned by commenters, namely the Electronic Recordkeeping

---

481 *See, e.g.*, *Nasdaq* v. *SEC*, 34 F.4th 1105, 1111-15 (D.C. Cir. 2022). This approach also follows SEC staff guidance on economic analysis for rulemaking. *See* SEC Staff, *Current Guidance on Economic Analysis in SEC Rulemaking* (Mar. 16, 2012), *available at* https://www.sec.gov/divisions/riskfin/rsfi_guidance_econ_analy_secrulemaking.pdf ("The economic consequences of proposed rules (potential costs and benefits including effects on efficiency, competition, and capital formation) should be measured against a baseline, which is the best assessment of how the world would look in the absence of the proposed action."); *Id.* at 7 ("The baseline includes both the economic attributes of the relevant market and the existing regulatory structure."). The best assessment of how the world would look in the absence of the proposed or final action typically does not include recently proposed actions, because that would improperly assume the adoption of those proposed actions.

482 *See, e.g.*, IAA Comment Letter 2; IAA Comment Letter 1; CAI Comment Letter; Comment Letter of the Securities Industry and Financial Markets Association, et al. (Mar. 31, 2023) ("SIFMA Comment Letter 1"). *See also* Comment Letter of the Investment Company Institute (Aug. 17, 2023) ("ICI Comment Letter 2") (stating the Commission should analyze the interconnections in related rules).